

Information Security Policy

Nexora Labs · Company Policy · Version 2.0 · Replaces version 1.0

Document ID	POL-INFOSEC-001	Version	2.0
Category	Information Security Policy	Effective date	2026-07-01
Owner	Infrastructure & Security	Review date	2027-07-01
Supersedes	POL-INFOSEC-001 v1.0	Status	Active

0. Summary of Changes in Version 2.0

This version replaces version 1.0 in full. Section 2.3 shortens the training deadline from seven days to three days. Section 2.1 now requires a hardware security key rather than any second factor. Section 3.3 grants Software Interns supervised read access to production repositories. Section 8 is new.

1. Purpose and Scope

- 1.1 This policy defines how Nexora Labs staff protect company systems, source code, customer data and credentials. It applies to every employee, contractor and intern from their first working day.
- 1.2 This policy is read together with the Data Privacy Policy (POL-PRIVACY-004) and the Deployment and Release SOP (SOP-DEPLOY-007).

2. Account Security

- 2.1 All employees must authenticate using a company-issued hardware security key. Application-based one-time codes are no longer accepted as a second factor for production systems.
- 2.2 Passwords must be at least sixteen characters long and must not be reused from any personal account.
- 2.3 Employees must complete the Information Security Basics module within three calendar days of their joining date.
- 2.4 Credentials shall never be shared over chat, email or a support ticket. Shared access is granted through the secrets manager only.
- 2.5 It is recommended that employees review their active sessions monthly and revoke devices they no longer use.

3. Source Code and Repository Handling

- 3.1 Backend Developers and Frontend Developers must not commit secrets, API keys or connection strings to any repository. All secrets are stored in the approved secrets manager.
- 3.2 Every change to a production service must be submitted as a pull request and approved by at least one other engineer before merge.
- 3.3 Software Interns may be granted read-only access to production repositories once their supervising engineer has confirmed completion of the Secure Coding module. Write access remains prohibited.
- 3.4 Developers may use approved AI coding assistants, provided no customer data or proprietary source is pasted into a third-party tool.

4. Production and Infrastructure Access

- 4.1 DevOps Engineers must demonstrate completion of the Production Access Certification before receiving standing production credentials.

4.2 Production access is granted on a least-privilege basis and must be reviewed by the Infrastructure lead every quarter.

4.3 Any direct write to a production database must be recorded in the change log within twenty-four hours.

4.4 Emergency break-glass access may be used during a Severity 1 incident. The Escalation Procedure (SOP-ESCALATE-011) applies in that situation.

5. Customer Data Handling

5.1 Employees must acknowledge the Data Handling Declaration before being granted access to any environment containing customer records.

5.2 Customer data must not be copied to a personal device, personal cloud storage or an unapproved analytics tool.

5.3 Data Analysts must work from the anonymised warehouse replica. Access to raw customer records requires written approval from the Data lead.

5.4 Exception: during a live production incident, a DevOps Engineer may query raw records where necessary to restore service. The query must be logged and reviewed within one working day.

6. Incident Reporting

6.1 A suspected security incident must be reported to the Security channel within thirty minutes of discovery.

6.2 Employees must not attempt to investigate a suspected breach on their own. Containment is handled by the Infrastructure team.

6.3 Employees are encouraged to report near misses, including phishing attempts that were not clicked.

7. Training and Acknowledgement

7.1 Every employee must acknowledge this policy in writing within three calendar days of joining.

7.2 All engineering staff must complete the Secure Coding assessment before the end of their first thirty days.

7.3 Optional: staff may attend the monthly security brown-bag session.

8. Third-Party and Vendor Tools

8.1 Employees must request approval through the Infrastructure team before connecting any third-party tool to a Nexora system.

8.2 Marketing staff, including SEO Specialists, must not grant analytics vendors access to authenticated customer pages.

8.3 A vendor holding customer data must be listed in the vendor register maintained by the Compliance function.